

CÓMO CREAR UN PROGRAMA DE GESTIÓN DE IDENTIDADES Y ACCESOS

Manual práctico y conciso de implementación

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

Propósito

Use este manual para trabajo legal, autorizado y defensivo. Adapte los controles al riesgo, las obligaciones legales, la accesibilidad y los recursos disponibles.

Fundamentos

- Trate la identidad como control de seguridad y capacidad empresarial.
- Defina fuentes autorizadas, tipos de identidad, propietarios, políticas, niveles de garantía y eventos de ciclo de vida.
- Incluya empleados, contratistas, clientes, socios, cargas, dispositivos, cuentas de servicio, API y agentes de IA.

Altas, cambios y bajas

- Cree acceso desde roles aprobados y datos verificados.
- Actualice acceso cuando cambien las funciones.
- Deshabilite cuentas, sesiones, tokens, certificados y credenciales físicas al terminar la relación.

Autenticación

- Use MFA resistente a phishing para acceso privilegiado y de alto riesgo.
- Aplique autenticación basada en riesgo y recuperación segura.
- Proteja inscripción, reemplazo y restablecimiento contra ingeniería social.

Autorización y privilegio mínimo

- Use RBAC y ABAC cuando corresponda.
- Separe funciones incompatibles y exija aprobación para accesos sensibles.
- Use acceso privilegiado justo a tiempo y temporal.

Identidades privilegiadas y de máquina

- Proteja credenciales y monitoree sesiones administrativas.
- Inventarie cuentas de servicio, secretos, certificados, claves, cargas e identidades no humanas.
- Asigne propietarios, rote, restrinja y elimine identidades abandonadas.

Revisiones y gobierno

- Revise acceso de alto riesgo con mayor frecuencia.
- Proporcione contexto y exija decisiones con evidencia.
- Controle cuentas huérfanas, acceso excesivo, combinaciones tóxicas, bajas fallidas y excepciones.

Federación, privacidad y hoja de ruta

- Valide confianza, atributos, claves, redirecciones, sesiones y responsabilidades.

- Minimice datos y ofrezca autenticación accesible.
- Días 1-30: inventario y bajas. Días 31-60: MFA, privilegios y revisiones. Días 61-90: automatización, identidades de máquina, métricas y pruebas.

Lista de implementación

- ☐ Responsable asignado
- ☐ Alcance aprobado
- ☐ Inventario completo
- ☐ Riesgos priorizados
- ☐ Políticas documentadas
- ☐ Controles implementados
- ☐ Evidencia conservada
- ☐ Excepciones con vencimiento
- ☐ Pruebas completadas
- ☐ Revisión directiva registrada

Referencias oficiales

- NIST SP 800-63-4: <https://www.nist.gov/publications/nist-sp-800-63-4-digital-identity-guidelines>
- NIST IAM Resource Center: <https://www.nist.gov/identity-and-access-management>
- NIST SP 800-207: <https://csrc.nist.gov/pubs/sp/800/207/final>

Licencia

Copyright © 2026 Alberto (Al) Leiva. Licencia CC BY-NC-SA 4.0.